OSINT & Recon Lab

Subdomain Enumeration Log

Subdomain	IP Address	Notes
www.example.com	93.184.216.34	Main web server
mail.example.com	93.184.216.35	Mail service (SMTP)
dev.example.com	93.184.216.36	Development server

Shodan Summary (50 words)

Using Shodan query **apache country:US**, multiple exposed Apache servers were identified. Some hosts showed outdated Apache versions, increasing vulnerability risk. Open ports like 80 and 443 were common. Misconfigured servers lacked proper security headers, making them susceptible to attacks like directory traversal and remote code execution.

2. Phishing Simulation

Credential Harvest Log

Timestamp	IP Address	Username/Password	Risk	Notes
2025-08-29 12:00:00	192.168.1.50	testuser/pass123	High	Successful capture

Explanation (Short)

A phishing page was cloned using Evilginx2 and deployed via Gophish. The victim entered credentials, which were captured successfully, demonstrating the effectiveness of social engineering attacks.

3. Vulnerability Exploitation

Vulnerability Log

Vulnerability	CVSS Score	Description
Struts RCE	9.8	Remote code execution flaw

Remediation

- Update Apache Struts to latest version
- Apply security patches
- Use Web Application Firewall (WAF)
- Restrict unnecessary ports

4. Lateral Movement

Pivoting Summary (50 words)

After gaining initial access, lateral movement was performed using Impacket's PsExec tool. Credentials were reused to access another system within the network. This allowed command execution remotely, enabling further compromise and expansion across the network while maintaining stealth through legitimate administrative tools.

Persistence Log

Technique	Tactic	Description	Notes
Scheduled Task	Persistence	T1053	Runs payload daily

5. Social Engineering Lab

Intel Gathering Log

Target ID	Data Source	Information	Notes
TID001	PhoneInfoga	Phone: 555-1234	Linked to target

Vishing Scenario (50 words)

An attacker impersonates a bank representative and calls the victim, claiming suspicious activity. The victim is pressured to verify account details. Using urgency and trust, the attacker collects sensitive information like OTPs and passwords, demonstrating how social engineering exploits human psychology rather than technical vulnerabilities.

6. Exploit Development Basics

Binary Analysis Summary (50 words)

The binary analysis revealed a buffer overflow vulnerability due to improper input validation. The program lacked stack protection mechanisms like canaries. Memory addresses were predictable, making exploitation easier. Using GDB, the return address was overwritten, allowing control over execution flow and demonstrating basic exploit development techniques.

7. Post-Exploitation

Credential Dump Log

Hash Type	Username	Hash Value
NTLM	Administrator	aad3b435b514...

Exfiltration Summary

Data exfiltration was simulated using DNS tunneling, where sensitive data was encoded into DNS queries. This method bypasses traditional firewall detection, demonstrating how attackers can stealthily extract information from compromised systems.

8. Red Team Report

Executive Summary

A simulated red team engagement was conducted to evaluate system security. The attack progressed from reconnaissance to data exfiltration. Multiple vulnerabilities were identified, including weak credentials and unpatched systems. The assessment highlights the need for improved monitoring, patch management, and employee awareness.

Findings

- Weak password policies
- Vulnerable web applications
- Lack of network segmentation
- Insufficient monitoring

Recommendations

- Enforce strong passwords
- Apply regular patches
- Implement IDS/IPS systems
- Conduct security awareness training

9. Capstone Project

Attack Log

Phase	Tool Used	Action Description	MITRE Technique
Recon	Recon-ng	Subdomain enumeration	T1595
Initial	Gophish	Phishing attack	T1566
Exploit	Metasploit	RCE exploit	T1190
Lateral	PsExec	Move across systems	T1021
Exfil	DNS	Data extraction	T1041

Blue Team Log

Timestamp	Alert Description	Source IP	Notes
2025-08-29 13:00:00	Suspicious Login	192.168.1.50	Phishing attempt

Final Report

A full red team simulation was conducted to assess the organization's security posture. The engagement began with reconnaissance using OSINT tools to gather domain and employee information. Initial access was achieved through a phishing attack, successfully capturing user credentials.

Exploitation was performed using Metasploit to gain remote code execution on a vulnerable system. Lateral movement was conducted using PsExec, allowing access to additional systems within the network. Persistence was established through scheduled tasks.

During post-exploitation, sensitive credentials were extracted using Mimikatz, and data exfiltration was simulated using DNS tunneling techniques. Blue team monitoring detected suspicious login activity, indicating partial detection capability.

Key findings include weak password policies, lack of patch management, and insufficient network monitoring. The organization is vulnerable to common attack techniques due to poor security hygiene.

Recommendations include enforcing strong password policies, implementing regular patch updates, deploying intrusion detection systems, and conducting employee awareness training to prevent phishing attacks.

Non-Technical Briefing

A security test was conducted to evaluate how vulnerable the system is to cyberattacks. The test showed that attackers could easily gain access through phishing emails and move across systems due to weak security controls. Sensitive data could also be extracted without detection.

The main issues identified were weak passwords, outdated software, and lack of monitoring. To improve security, it is recommended to update systems regularly, use stronger passwords, and train employees to recognize phishing attempts. Implementing better security tools will help detect and prevent future attacks.